

NLS

CYBERSECURITY FRAMEWORK

ARTUR GUIMARÃES DOS SANTOS LEITE
MARINA SCHWERZ BON
PEDRO BOEIRA WEBBER

NIST CSF 2.0

Conjunto de **padrões, diretrizes e melhores práticas** desenvolvido pelo National Institute of Standards and Technology (NIST) dos EUA.

Fornece **orientações abrangentes** para reduzir riscos de segurança da informação de forma eficaz.

Framework **voluntário e flexível**, projetado para ser integrar aos processos de segurança existentes em setor, de qualquer organização.

Criado para aprimorar a postura de segurança cibernética das organizações e promover uma **linguagem comum em gerenciamento de risco**.

Lançado em 2014, rapidamente tornando-se uma das estruturas de segurança mais adotadas nos EUA.

Hoje, é utilizado por empresas de todos os portes, servindo como base para entender e comunicar riscos **de forma consistente**.

Oferece abordagem priorizada, flexível e custo-efetiva para proteção e resiliência cibernética.

O NIST CSF é **orientado a riscos e resultados**, permitindo que cada organização adapte controles conforme suas necessidades e nível de maturidade.

Por ser escrito em linguagem acessível e não técnica, ele **facilita a comunicação entre equipes técnicas e liderança executiva**, criando um entendimento compartilhado do risco cibernético.

Em suma, o NIST CSF ajuda a transformar programas complexos de segurança em um processo transparente e repetível de gestão de risco.

COMPO NENTES

O NIST CSF é composto de **três componentes principais**:

- o **Núcleo** (Core);
- os **Perfis** (Profiles) e;
- as **Camadas de Implementação** (Tiers).

Também inclui Referências Informativas para padrões de segurança existentes.

NÚCLEO (CORE)

Funções: Seis Funções Primárias: Identificar, Proteger, Detectar, Responder, Recuperar e Governar.

Representam **pilares de um programa de segurança**, o nível mais alto de abstração. Não são etapas sequenciais, mas atividades simultâneas e contínuas.

Categorias: cada Função se desdobra em Categorias que abrangem diferentes domínios da segurança.

Subcategorias: subdivisões das categorias. Descrevem **resultados específicos** que a organização deve atingir. Representam o que deve ser feito, mas não ditam como fazer.

FUNÇÕES

Identify: Saber o que proteger, quem é responsável e quais riscos priorizar. *Categorias:* ID.AM, ID.BE, ID.GV, ID.RA, ID.RM, ID.SC.

Protect: Foca em evitar ataques ou reduzir danos. *Categorias:* PR.AC, PR.AT, PR.DS, PR.IP, PR.MA, PR.PT.

Detect: Garante que incidentes sejam descobertos rapidamente. *Categorias:* DE.AE, DE.CM, DE.DP.

Respond: O foco é reduzir impacto, restaurar controle e comunicar adequadamente as partes envolvidas. *Categorias:* RS.RP, RS.CO, RS.AN, RS.MI, RS.IM.

Recover: Envolve backup, disaster recovery e retorno rápido às operações, preservando confiança e continuidade. *Categorias:* RC.RP, RC.IM, RC.CO.

Govern: Garante que segurança seja uma decisão estratégica, não só técnica.

Function	Category	ID
Identify	Asset Management	ID.AM
	Business Environment	ID.BE
	Governance	ID.GV
	Risk Assessment	ID.RA
	Risk Management Strategy	ID.RM
	Supply Chain Risk Management	ID.SC
Protect	Identity Management and Access Control	PR.AC
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Information Protection Processes & Procedures	PR.IP
	Maintenance	PR.MA
	Protective Technology	PR.PT
Detect	Anomalies and Events	DE.AE
	Security Continuous Monitoring	DE.CM
	Detection Processes	DE.DP
Respond	Response Planning	RS.RP
	Communications	RS.CO
	Analysis	RS.AN
	Mitigation	RS.MI
	Improvements	RS.IM
Recover	Recovery Planning	RC.RP
	Improvements	RC.IM
	Communications	RC.CO

Subcategory	Informative References
ID.BE-1: The organization's role in the supply chain is identified and communicated	COBIT 5 APO08.01, APO08.04, APO08.05, APO10.03, APO10.04, APO10.05 ISO/IEC 27001:2013 A.15.1.1, A.15.1.2, A.15.1.3, A.15.2.1, A.15.2.2 NIST SP 800-53 Rev. 4 CP-2, SA-12
ID.BE-2: The organization's place in critical infrastructure and its industry sector is identified and communicated	COBIT 5 APO02.06, APO03.01 ISO/IEC 27001:2013 Clause 4.1 NIST SP 800-53 Rev. 4 PM-8
ID.BE-3: Priorities for organizational mission, objectives, and activities are established and communicated	COBIT 5 APO02.01, APO02.06, APO03.01 ISA 62443-2-1:2009 4.2.2.1, 4.2.3.6 NIST SP 800-53 Rev. 4 PM-11, SA-14
ID.BE-4: Dependencies and critical functions for delivery of critical services are established	COBIT 5 APO10.01, BAI04.02, BAI09.02 ISO/IEC 27001:2013 A.11.2.2, A.11.2.3, A.12.1.3 NIST SP 800-53 Rev. 4 CP-8, PE-9, PE-11, PM-8, SA-14
ID.BE-5: Resilience requirements to support delivery of critical services are established for all operating states (e.g. under duress/attack, during recovery, normal operations)	COBIT 5 DSS04.02 ISO/IEC 27001:2013 A.11.1.4, A.17.1.1, A.17.1.2, A.17.2.1 NIST SP 800-53 Rev. 4 CP-2, CP-11, SA-14

PERFIS (PROFILES)

Um perfil é **um retrato da postura de segurança cibernética** de uma organização em termos dos resultados do Núcleo alcançados.

Permite **comparar** o estado atual (Current Profile) de segurança com um estado desejado (Target Profile).

Ajuda a alinhar as atividades de segurança com os objetivos de negócio, tolerância a riscos e recursos disponíveis da organização.

A comparação entre perfil atual e alvo evidencia **lacunas de segurança** que devem ser tratadas, orientando a priorização de melhorias.

Uma organização pode desenvolver múltiplos Perfis para diferentes unidades de negócio, caso possua ambientes com necessidades distintas.

1 - PARCIAL

Implementação *ad hoc* e reativa. A organização possui **consciência limitada** dos riscos de segurança, práticas são informais ou isoladas.

2 - RISCO INFORMADO

A organização **já reconhece os riscos cibernéticos** e há comunicação informal sobre segurança. Entretanto, a gestão de risco **ainda não é totalmente estabelecida** ou consistente em toda a empresa.

3 - REPETÍVEL

A organização possui processos de gestão de risco cibernético **formalizados em toda a empresa**. A alta direção está ciente dos riscos e apoia as iniciativas de segurança.

4 - ADAPTATIVO

A organização possui **postura resiliente** e capacidade de **adaptação contínua** diante de ameaças, processos de melhoria contínua estão implantados e a gestão de risco cibernético está integrada à **cultura organizacional**.

CAMADAS DE IMPLEMENTAÇÃO (TIERS)

REFERÊNCIAS INFORMATIVAS

*Para cada subcategoria, o NIST CSF fornece **referências** para controles e práticas de outras estruturas reconhecidas, como **ISO/IEC 27001**, **COBIT 5**, **Controles CIS**, **ISA 62443** e **NIST SP 800-53**.*

*Essas Informative References mostram métodos específicos para atingir os resultados da subcategoria, **conectando o framework a padrões já existentes**.*

*Isso torna o CSF um **hub integrador**, permitindo que empresas aproveitem investimentos ou conformidades **já existentes**.*

IMPLEMENTAÇÃO

Maturidade (Implementation Tiers)

Formalizada pelos níveis de implementação, estruturados em três dimensões principais:

1. Processo de gerenciamento de risco;
2. Programa de gerenciamento de risco e;
3. Participação externa.

O NIST ressalta que os Tiers servem como mecanismo para posicionamento estratégico, comunicação e definição de metas, **não como imposição normativa**.

Essa visão permite que cada entidade, desde pequenas empresas até grandes instituições, escolha conscientemente seu “nível de maturidade”: ponderando recursos, perfil de risco e contexto de governança.

Tier 4: Adaptive

Tier 3: Repeatable

Tier 2: Risk-Informed

Tier 1: Partial

IMPLEMENTAÇÃO

Artefatos de Implementação

- Perfis Organizacionais (Organizational Profiles):**
Representação formal da postura de segurança cibernética da organização.
- Planilha de Perfil (template):** O NIST disponibiliza um template em formato XLSX para perfis organizacionais.
- Guia de Início Rápido (Quick-Start Guide):** O NIST orienta sobre como criar e usar esses perfis num processo de cinco etapas: *definir escopo, avaliar perfil atual, definir perfil alvo, realizar análise de lacunas, e priorizar ações.*
- Referências Informativas (Informative References):** O CSF 2.0 mapeia suas subcategorias a recursos, práticas e controles de outras publicações NIST.
- Exemplos de Implementação (Implementation Examples):** O NIST mantém exemplos práticos de como satisfazer determinadas subcategorias.
- Ferramentas Online:** Com o CSF 2.0, há uma “CSF 2.0 Reference Tool” pesquisável.

	A	B	C	D	E	F	G	H
1	CSF Outcome (Function, Category, or Subcategory)	CSF Outcome Description	Include d in Profile?	Rationale	Current Priority	Current Status	Current Policies, Processes, and Procedures	Current Internal Practices
2	GV	The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored						
3	GV.OC	The circumstances - mission, stakeholder expectations, dependencies, and legal, regulatory, and contractual requirements - surrounding the organization's cybersecurity risk management decisions are understood						
4	GV.OC-01	The organizational mission is understood and informs cybersecurity risk management						
5	GV.OC-02	Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered						
6	GV.OC-03	Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed						
7	GV.OC-04	Critical objectives, capabilities, and services that stakeholders depend on or expect from the organization are understood and communicated						
8	GV.OC-05	Outcomes, capabilities, and services that the organization depends on are understood and communicated						
9	GV.RM	The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated, and used to support operational risk decisions						
10	GV.RM-01	Risk management objectives are established and agreed to by organizational stakeholders						
11	GV.RM-02	Risk appetite and risk tolerance statements are established, communicated, and maintained						
12	GV.RM-03	Cybersecurity risk management activities and outcomes are included in enterprise risk management processes						
13	GV.RM-04	Strategic direction that describes appropriate risk response options is established and communicated						
14	GV.RM-05	Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties						
15	GV.RM-06	A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated						
	GV.RM-07	Strategic opportunities (i.e., positive						

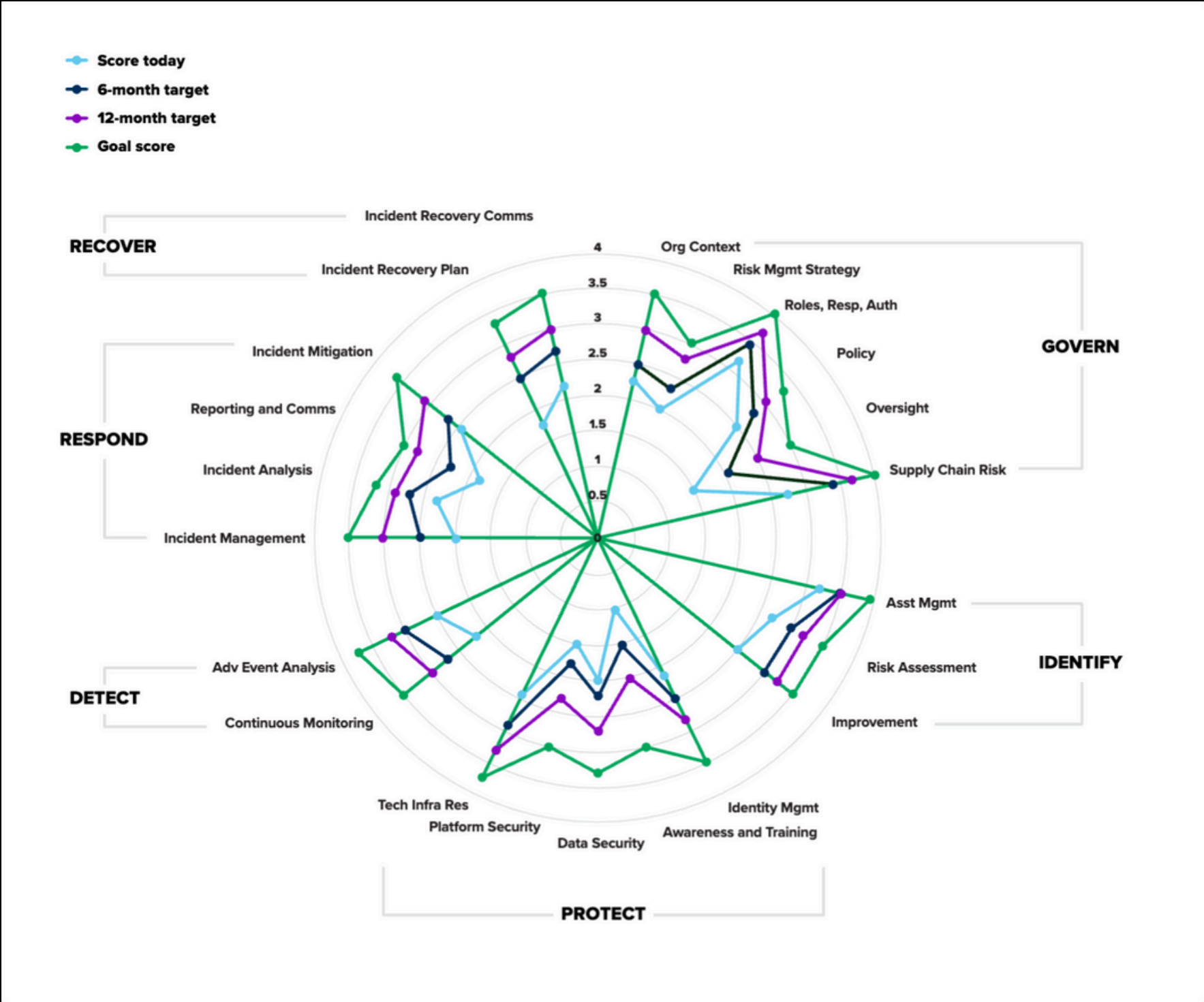
IMPLEMENTAÇÃO

Análise de Resultados

Comparação entre o perfil atual e o perfil alvo (**gap analysis**), e pelo uso dos Tiers como referência de progresso (SP 1301).

Permite **priorizar** ações e **elaborar** um plano de ação coerente. A organização pode revisitar seus perfis, avaliar o progresso e reajustar seu perfil alvo. A adoção dos Tiers serve como métrica qualitativa para avaliar a evolução da maturidade institucional.

Por meio dos perfis e análise de lacunas, a organização pode **traduzir** aspectos técnicos de suas iniciativas de segurança para linguagem compreensível por stakeholders. A versão 2.0 enfatiza que a estrutura deve servir para “**comunicar internamente e externamente sobre riscos, capacidades e expectativas**”.



CONSIDERAÇÕES FINAIS

Implementar o NIST CSF **não é tarefa mecânica nem estática**. A maturidade é um horizonte que cada organização escolhe em função de seu próprio contexto.

Os artefatos, perfis, guias, planilhas, e ferramentas **refletem a realidade interna** e indicam caminhos possíveis, já a análise de resultados **encarna o movimento de confrontação e superação**.

Essa abordagem permite não apenas mitigar riscos, mas **cultivar uma cultura de resiliência e aprendizado contínuo**. A estrutura do NIST CSF é um chamado à **responsabilidade** não só técnica, mas ética e estratégica, diante do abismo da paisagem cibernética.

REFERÊNCIAS

1. <https://www.ibm.com/br-pt/think/topics/nist>
2. <https://www.nist.gov/blogs/taking-measure/identify-protect-detect-respond-and-recover-nist-cybersecurity-framework>
3. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1271pt.pdf>
4. <https://www.techrepublic.com/article/nist-cybersecurity-framework-the-smart-persons-guide/>
5. <https://www.optiv.com/insights/discover/blog/nist-cybersecurity-framework-csf-20-functions-profiles-outcomes-and-controls>
6. <https://novared.com.br/o-que-e-o-nist-cybersecurity-framework-nist-csf/>
7. <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
8. <https://www.cybersaint.io/blog/the-nist-cybersecurity-framework-implementation-tiers-explained>
9. https://www.nist.gov/system/files/documents/2023/01/19/CSF_2.0_Concept_Paper_01-18-23.pdf
10. <https://www.nist.gov/publications/nist-cybersecurity-framework-20-quick-start-guide-creating-and-using-organizational>
11. <https://www.nist.gov/cyberframework/profiles>

OBRIGADO

PELA ATENÇÃO!